

A Comprehensive Survey on Cybersecurity Challenges in the Internet of Medical Things (IoMT)

Survey Article | Healthcare Cybersecurity | 2026

Md. Fairuz Anam
ID: 23101122

Department of Computer
Science and Engineering
University of Asia Pacific
Dhaka, Bangladesh
23101122@uap-bd.edu

Aunjolee Nusrath Anu
ID: 23101154

Department of Computer
Science and Engineering
University of Asia Pacific
Dhaka, Bangladesh
23101154@uap-bd.edu

Dalila Binte Alam
ID: 23101157

Department of Computer
Science and Engineering
University of Asia Pacific
Dhaka, Bangladesh
23101157@uap-bd.edu

Ejaj Ahmmmod Lemon
ID: 23101160

Department of Computer
Science and Engineering
University of Asia Pacific
Dhaka, Bangladesh
23101160@uap-bd.edu

ABSTRACT

The Internet of Medical Things (IoMT) has fundamentally altered the delivery of healthcare by enabling real-time remote patient monitoring, real-time clinical decision support, and data-driven disease management at a scale previously unattainable. Interconnected medical devices — spanning wearable biosensors, implantable monitors, infusion pumps, imaging systems, and hospital information platforms — now form an expansive digital infrastructure on which patient safety directly depends. That dependency, however, introduces a cybersecurity attack surface of extraordinary breadth and consequence. This survey synthesizes the current body of knowledge on IoMT cybersecurity by examining the ecosystem's architectural layers, cataloguing the principal threat categories that exploit them, evaluating the mitigation frameworks that have been proposed or deployed, and identifying the most significant research gaps that remain unresolved. The analysis draws on recent empirical work demonstrating that the majority of deployed IoMT devices carry moderate-to-high cybersecurity risk scores, with hospital information systems and infusion pumps consistently exhibiting the greatest security vulnerabilities. The survey further examines the active debate between conventional multi-layered security paradigms and emerging adaptive frameworks combining deep reinforcement learning with blockchain technology. Key findings reveal that no proposed solution has yet been validated in a live clinical environment, that device complexity and network integration depth predict vulnerability more reliably than device age alone, and that the field's prevailing technical orientation systematically underweights human factors, organizational constraints, and manufacturer incentive structures. The paper concludes by articulating the single open question whose resolution would most reshape both research priorities and institutional investment decisions in healthcare cybersecurity.

Keywords: *IoMT; cybersecurity; healthcare data privacy; medical device vulnerability; DDoS; blockchain; deep reinforcement learning; risk assessment; network security.*

1. Introduction

Healthcare has entered an era defined by pervasive connectivity. Bedside monitors stream vital signs to cloud analytics platforms; insulin pumps receive dosing instructions through wireless protocols; surgical robots transmit telemetry across hospital networks; and wearable patches relay electrocardiographic data to cardiologists hundreds of miles away. This constellation of interconnected medical devices constitutes what is now broadly referred to as the IoMT — a concept that encompasses not only a network of hardware devices but an entire sociotechnical infrastructure on which clinical practice, patient safety, and institutional operations increasingly depend. The scale of this technological transformation is both significant and quantifiable. Market analyses indicate that the sector is expected to increase from nearly USD 48.7 billion in 2022 to around USD 370.9 billion by 2032, representing an increase of more than 660 percent within a single decade [6]. This rapid expansion highlights the accelerating adoption of connected technologies within modern healthcare systems. In contemporary hospital environments, it is estimated that each inpatient bed is supported by approximately ten to fifteen connected medical devices. As a result, a large healthcare institution may be required to manage hundreds of thousands of interconnected endpoints simultaneously. While this level of connectivity introduces complexity, it also enables substantial clinical advantages. The benefits of such integration are well-established and widely documented. These include reduced hospital readmission rates, earlier detection of patient deterioration, improved management of chronic diseases, and enhanced access to specialized medical care for populations in remote or underserved regions [1], [8]. Collectively, these advancements contribute to more efficient, responsive, and patient-centered healthcare delivery.

Yet connectivity that enables care also enables attack. The same network pathways that carry glucose readings from a patient's subcutaneous sensor to an endocrinologist's dashboard can carry ransomware from a compromised gateway to a hospital's electronic health record system. The same wireless protocols that allow an implantable pacemaker to transmit arrhythmia data to a cardiologist can, under certain conditions, allow an unauthorized party to intercept or manipulate that transmission. The same administrative efficiency created by integrating IoMT devices with hospital information systems also means that a vulnerability in a single infusion pump can serve as an entry point into the broader network infrastructure.

This survey addresses the cybersecurity dimensions of IoMT comprehensively. It examines the architectural layers through which IoMT ecosystems are organized, the principal threat categories that target those layers, the mitigation frameworks that researchers and practitioners have proposed, and the gaps that the existing literature has not yet adequately addressed. The analysis is grounded in recent empirical work on device vulnerability distributions, emerging proposals for adaptive security frameworks, and systematic reviews of network security techniques [1], [2], [3], [4], [5].

Market Growth Forecast

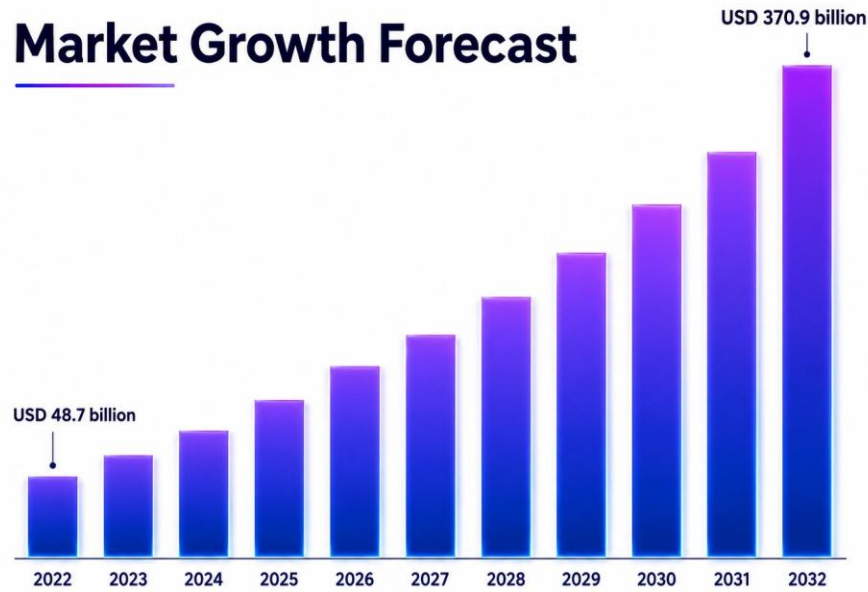


Fig. 1. Projected IoMT Market Growth from 2022 to 2032.

Figure 1 graphically shows the market growth of IoMT from 2022 to 2032. It is a past to future analysis of IoMT about how it was before and how it will be after 10 years. It makes us clear about the future scope and values of IoMT in human life.

The paper is organized as follows. Section 2 reviews existing literature on IoMT cybersecurity and identifies prior methodological approaches. Section 3 provides an overview of the IoMT ecosystem and its architectural structure. Section 4 presents the results of a survey analysis. Section 5 examines the principal cybersecurity challenges confronting each layer of the architecture. Section 6 surveys mitigation strategies and security frameworks proposed in the literature. Section 7 presents a critical analysis of evidentiary quality and assumptions underlying current research. Section 8 identifies key research gaps and future directions. Section 9 concludes by highlighting the field's most consequential open question.

2. Literature Review

The five studies examined in this survey collectively represent the current state of IoMT cybersecurity scholarship across its most important methodological modes: descriptive synthesis, comprehensive architectural review, conceptual analysis of privacy challenges, quantitative risk modelling, and systematic network security survey [1], [2], [3], [4], [5]. Each study contributes a distinct analytical lens; together, they reveal both the field's shared commitments and its genuine unresolved disputes.

Bayyapu's study [1] offers one of the field's foundational descriptive syntheses. The paper maps the dual character of IoMT adoption — its transformative clinical benefits on one side, and its structural security liabilities on the other — with a scope that encompasses patient care enhancement, disease

management, resource optimization, and patient engagement alongside their corresponding cybersecurity risks. The study's central contribution is its systematic enumeration of IoMT cybersecurity challenges across five categories: vulnerable devices, unencrypted data transmission, lack of standardization, insider threats, and limited institutional visibility and control. For each challenge, Bayyapu identifies both the mechanism of harm and the class of mitigation required, producing a conceptual map that subsequent researchers have elaborated. The mitigation framework proposed — implementing robust security protocols, segmenting medical networks, applying access controls, raising staff awareness, and collaborating with cybersecurity experts — remains the most widely cited baseline in prescriptive IoMT security literature.

Methodologically, the study is a non-systematic descriptive review. No formal search strategy, inclusion criteria, or source enumeration is documented, which limits replicability and makes the evidential basis for individual claims difficult to verify. Despite these limitations, the paper's conceptual breadth and accessible framing make it a foundational orientation document for the field, and its identification of insider threats as a primary risk category represents a durable contribution.

The comprehensive review by Mutua and Bitok [\[2\]](#) provides the most architecturally complete mapping of the IoMT ecosystem available in the current literature. The study organizes its analysis across six distinct layers — device, connectivity, data processing, application, user interface, and security — and for each layer systematically identifies the enabling technologies deployed, the security mechanisms applicable, and the vulnerability profiles characteristic of that layer. This layered framework serves as the structural backbone for the present survey. Mutua and Bitok's enumeration of enabling technologies is notably comprehensive. At the device layer, the study covers biosensors, wearables, implantable sensors, ingestible sensors, environmental sensors, motion sensors, imaging technologies, remote monitoring devices, biometric identification systems, and smart textiles. At the connectivity layer, the study maps communication protocols from Bluetooth Low Energy and Zigbee through LoRaWAN and 5G cellular to satellite communication, with attention to the distinct security implications of each.

The security challenges identified span data privacy and confidentiality, data integrity, device security and vulnerabilities, interoperability and standardization issues, authentication weaknesses, network security and communication risks, scalability of security updates, regulatory compliance, insider threats, data overload and analytics security, physical device security, and emerging threats from advanced technologies including blockchain, augmented reality, and Bio-Nano Things. This taxonomy is the most comprehensive in the literature under review.

Yazid's study [\[3\]](#) focuses specifically on the intersection of cybersecurity and patient privacy in IoMT contexts. The paper's analytical contribution lies in its equal treatment of five risk categories — data breaches, vulnerable devices, lack of encryption, insider threats, and regulatory compliance — presenting these not as a hierarchy with a single root cause but as five co-equal dimensions of a systemic security challenge. On data breaches, Yazid documents the pathways through which IoMT-collected medical data

reaches malicious actors, and the downstream harms including identity theft, insurance fraud, and financial loss. The study's treatment of encryption gaps is notable for its specificity: secure sockets layer and transport layer security are identified as concrete implementation standards. On regulatory compliance, Yazid provides a more detailed treatment of HIPAA and GDPR requirements than any other study in this set, explicitly noting that non-compliance exposes organizations to fines and legal penalties.

The study by Akram and colleagues [\[4\]](#) represents the most methodologically distinct contribution in this survey's source literature. Where the preceding three studies synthesize existing knowledge through literature review, Akram et al. develop and empirically apply a quantitative risk assessment model to a dataset consisting of 150 IoMT devices from five distinct device categories operating within hospitals in the United States. The risk assessment model integrates three parameters: vulnerability severity, threat probability, and operational impact. These are combined through a multiplicative formula — $\text{Risk} = \text{Threat Probability} \times \text{Vulnerability Severity} \times \text{Impact}$ — to generate composite risk scores for each device category. The model is then applied to analyze vulnerability distribution across infusion pumps (35 devices), patient monitors (30), medical imaging systems (25), wearable healthcare devices (30), and hospital information management systems (30).

Infusion pumps exhibit the highest vulnerability prevalence at 74 percent, followed by imaging systems at 72 percent, hospital information systems at 70 percent, patient monitors at 63 percent, and wearable devices at 47 percent. When composite risk scores are computed, hospital information systems rank highest with a mean score of 8.1, followed by infusion pumps at 7.8 and imaging systems at 7.3, with wearable devices at the lower end at 4.6. Risk level classification reveals that 37 percent of analyzed devices fall into the high-risk category, 42 percent into medium risk, and only 21 percent into low risk.

The survey by Tarish, Hassan, Ariffin, and Jaber [\[5\]](#) addresses the network security dimensions of IoMT with a focus on distributed denial of service threats and the two most promising advanced defensive frameworks: deep reinforcement learning and blockchain technology. The taxonomy of DDoS attack variants relevant to IoMT contexts developed by Tarish et al. is the most systematic available in the source literature. The study identifies volumetric attacks, UDP floods, SYN floods, application-layer attacks, IoT botnet attacks, reflection and amplification attacks, and IoT device exploitation as distinct attack categories. A hybrid PCA-GWO-based deep neural network classifier achieved 99.90 percent accuracy with a 32 percent reduction in training time compared to baseline methods. A combined deep learning and SDN-based detection framework attained 99.99 percent accuracy in detecting botnet attacks on a botnet dataset.

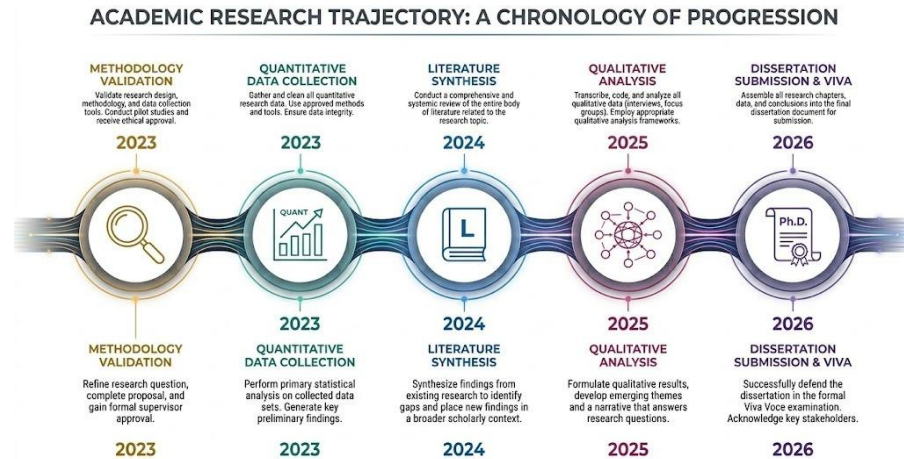


Fig. 2. Comparative Timeline of Five Source Studies.

Following figure 2 shows the comparative timeline of five study sources, it shows a comparisons of different academic research trajectory where it highlights the progression, this figure shows the methodology validation, quantitative data collection, literature synthesis, qualitative analysis and dissertation submission and viva. which are explained before.

2.2 Comparative Synthesis of Source Studies

The five studies, taken together, reveal both the field's settled knowledge and its genuinely contested terrain. Table I provides a structured comparative overview of their methodologies, primary contributions, and principal limitations, establishing the evidential foundation on which the remainder of this survey builds.

Table I: Comparative Analysis of Source Studies

Author(s) / Year	Methodology	Core Contribution	Primary Finding	Key Limitation
Bayyapu (2023)	Descriptive review	Dual mapping of IoMT benefits and cybersecurity risks	Multi-layered controls required; insider threats under-addressed	No systematic protocol
Mutua & Bitok (2025)	Systematic review	Six-layer IoMT architecture with per-layer security mapping	Complexity and integration depth predict risk	No empirical testing
Yazid (2023)	Conceptual analysis	Co-equal treatment of five risk categories	Insider threats need behavioral controls	Body text partial; no protocol

Author(s) / Year	Methodology	Core Contribution	Primary Finding	Key Limitation
Akram et al. (2026)	Risk modelling	Multiplicative risk model on 150 IoMT devices	HIS (8.1) and infusion pumps (7.8) highest risk; 37% high-risk	Simulated environment
Tarish et al. (2024)	Review + taxonomy	DDoS taxonomy; DRL and blockchain framework	DRL $\approx 99\%$ on benchmark datasets	No clinical validation

Three cross-cutting observations emerge from this comparative synthesis. First, the literature exhibits a methodological hierarchy in which quantitative and empirical approaches are rare while descriptive and review-based approaches dominate. Second, all five studies converge on the inadequacy of any single security mechanism while diverging on which mechanisms deserve priority. Third, the studies' recommendations are internally consistent at the level of general principle but diverge significantly on technical specificity, architecture, and relative emphasis.

3. The IoMT Ecosystem: Architecture and Scope

3.1 Defining the Internet of Medical Things

The IoMT refers to the interconnected network of medical devices, sensors, software applications, and healthcare information systems that collect, transmit, and analyze health-related data through internet-based infrastructures [6], [8]. It represents a domain-specific application of broader IoT principles, distinguished by the sensitivity of the data it handles, the criticality of the services it supports, and the regulatory environments within which it operates.

The IoMT ecosystem encompasses extraordinary device diversity. At the smallest scale, ingestible sensors the size of pharmaceutical capsules monitor gastrointestinal conditions and transmit pH, temperature, and pressure readings wirelessly to external receivers. At the largest scale, magnetic resonance imaging systems and computed tomography scanners generate gigabytes of imaging data that flow through hospital networks to radiologists and automated diagnostic algorithms. Between these extremes lie wearable biosensors, implantable cardiac monitors, glucose management systems, smart infusion pumps, robotic surgical assistants, environmental monitoring arrays, and the electronic health record platforms that aggregate data from all of them.

3.2 Architectural Layers

Understanding IoMT security requires understanding the layered architecture through which its components are organized. Five primary layers structure the ecosystem, each with distinct security requirements and vulnerability profiles.



Fig. 3. Five-Layer Architectural Framework of IoMT.

Figure 3 explains the layers of architectural framework of IoMT, which we are discussing in the section [3.2] elaborately. This is only a visual representation of what are there.

3.2.1 Device Layer

The device layer encompasses the physical hardware that generates health data. This includes wearable devices such as smartwatches and biosensor patches, implantable devices including pacemakers and continuous glucose monitoring devices, fixed hospital equipment including ventilators and patient monitoring systems, and environmental sensing devices installed in clinical environments. Devices at this layer are characterized by constrained computational resources, limited power budgets, and the need for minimal human intervention during operation. These characteristics create direct security tensions: robust encryption and authentication mechanisms require computational resources that many IoMT devices cannot spare without compromising their primary clinical functions.

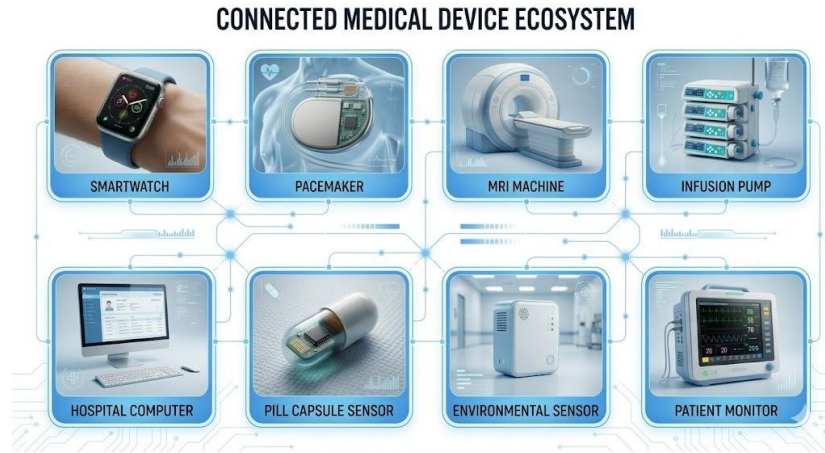


Fig. 4. Taxonomy of IoMT Device Categories in Healthcare.

3.2.2 Connectivity Layer

The connectivity layer serves as the fundamental communication infrastructure that links medical devices to networks, gateways, and cloud-based platforms. This layer incorporates a range of communication protocols, each selected based on specific performance and operational requirements. For instance, Bluetooth Low Energy (BLE) is widely used for low-range, energy-efficient communication between smart devices and mobile phones, while Wi-Fi supports higher-bandwidth integration within clinical networks. Zigbee is often employed in mesh-based sensor networks, while LoRaWAN facilitates long-range communication suitable for remote monitoring. Additionally, 4G and 5G cellular networks play a critical role in supporting mobile health applications.

Each of these communication protocols exhibits distinct security characteristics and potential vulnerability profiles. The emergence of 5G technology has introduced ultra-low latency capabilities, which are essential for real-time medical applications such as telesurgery. However, this advancement also contributes to an expanded attack surface, thereby increasing the potential exposure to cybersecurity threats.

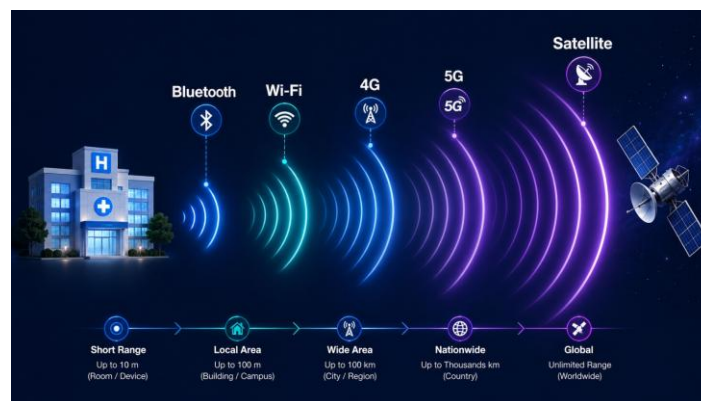


Fig. 5. Wireless Communication Protocols Across the Connectivity Layer

Figure 5 shows the wireless communication that layers are connected with. It shows how Bluetooth, wifi, 4G and 5G and satellites are all aligned in layers.

3.2.3 Data Processing Layer

The data processing layer transforms raw device readings into clinically actionable information through edge computing and cloud computing resources. Edge computing performs initial analysis at or near the device to minimize latency and reduce bandwidth demands — critical for applications requiring immediate response, such as seizure detection or arrhythmia alerts. Cloud computing platforms provide the computational capacity for large-scale analytics, machine learning model training, and longitudinal health trend analysis. The security implications of this dual architecture are significant: data processed at the edge may receive less rigorous security oversight than centralized cloud environments, while data in transit between edge and cloud represents a persistent interception risk.

3.2.4 Application and User Interface Layers

The application layer translates processed data into clinical tools: telemedicine platforms, remote patient monitoring dashboards, clinical decision support systems, electronic health record integrations, and patient-facing mobile health applications. The user interface layer provides the access points through which clinicians, patients, and administrators interact with IoMT systems. Both layers represent significant attack surfaces, as they are the points at which human behavior intersects with technical systems.

3.2.5 Security Layer

The security layer is cross-cutting rather than discrete, encompassing the encryption protocols, authentication mechanisms, access control frameworks, intrusion detection systems, and compliance monitoring tools that operate across all other layers. Key technologies comprise AES-256 encryption for stored data, Transport Layer Security for transmitted data, multi-factor authentication for user verification, Role-Based Access Control for managing user privileges, and Attribute-Based Access Control for detailed authorization control [2], [13]. Adherence to regulatory frameworks such as HIPAA in the United States and GDPR in the European Union serves as an additional factor influencing the design of security layers.

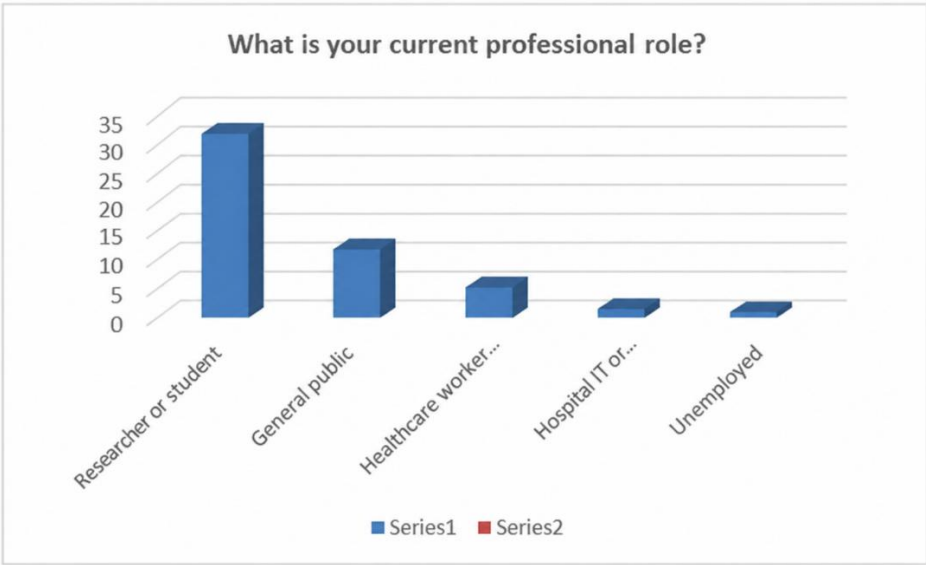
Table II: IoMT Architectural Layers and Primary Security Technologies

Layer	Key Technologies	Primary Risk	Mitigation Focus
Device	Biosensors, wearables, implantable, imaging systems	Limited computation for security	Lightweight encryption, secure boot
Connectivity	BLE, Wi-Fi, Zigbee, Lora WAN, 5G, NB-IoT	Interception, man-in-the-middle	TLS/HTTPS, secure protocols
Data Processing	Edge computing, cloud platforms, ML pipelines	Data tampering, adversarial ML	Validation, encrypted pipelines
Application	EHRs, telemedicine, CDSS, mHealth apps	Unauthorized access, API exploit	RBAC, ABAC, secure APIs

Layer	Key Technologies	Primary Risk	Mitigation Focus
User Interface	Web portals, mobile apps, voice interfaces	Phishing, credential theft	MFA, security awareness training
Security	AES-256, TLS, IDPS, blockchain, DRL	Complexity-induced vulnerabilities	Unified frameworks, monitoring

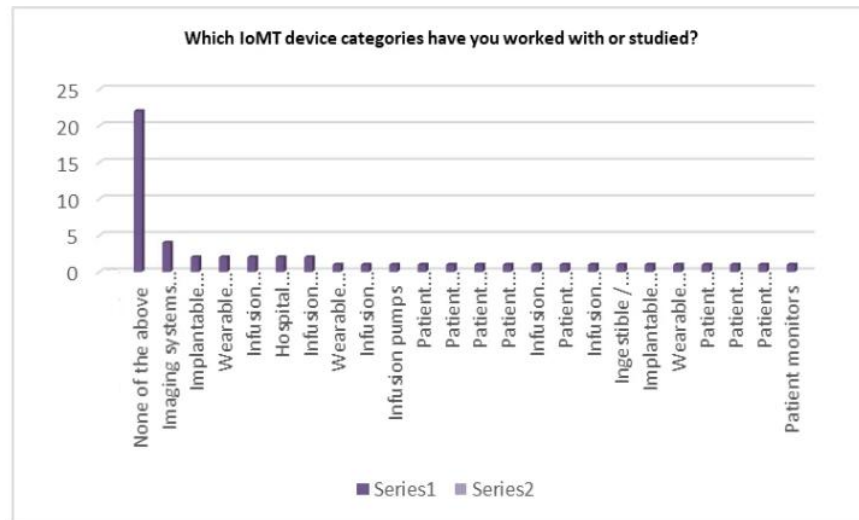
4. Survey Analysis

1.



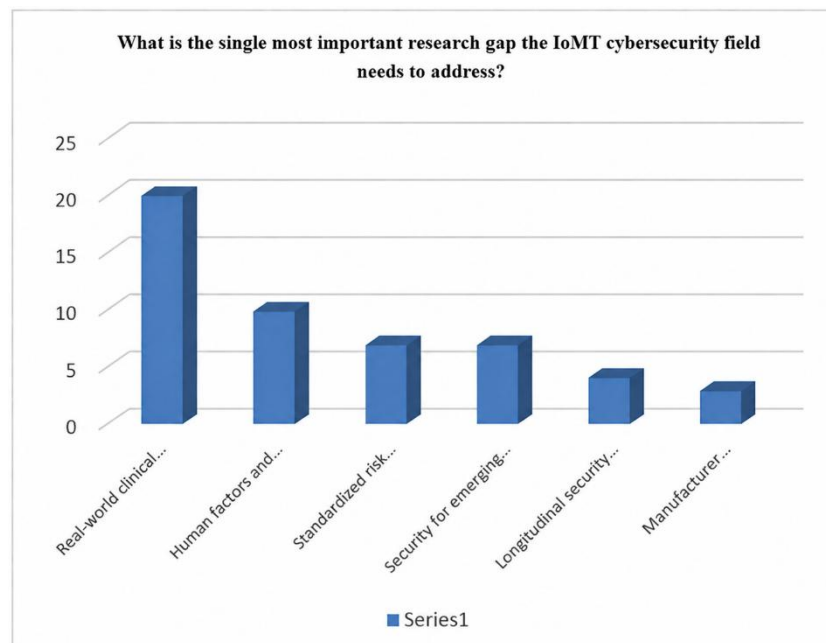
Following graph is the representation of what are the roles of the responders it shows that mostly are researchers or student, followed by general public and health workers and unemployed persons are the less responders.

2.



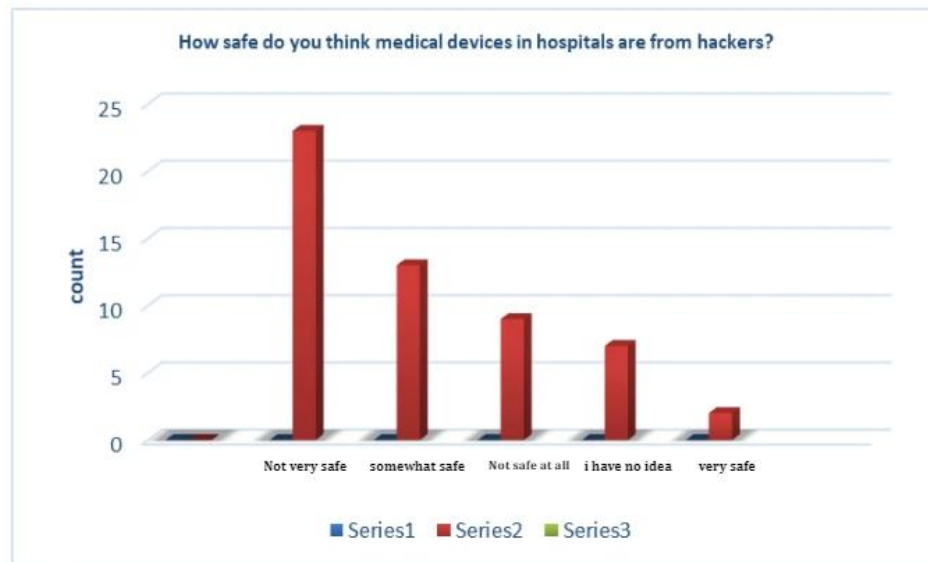
Representation of graph given before are which IoMT device categories have the responders worked or studied about. Most of them had no idea but a certain amount of people said they know about imagining systems and wearables.

3.



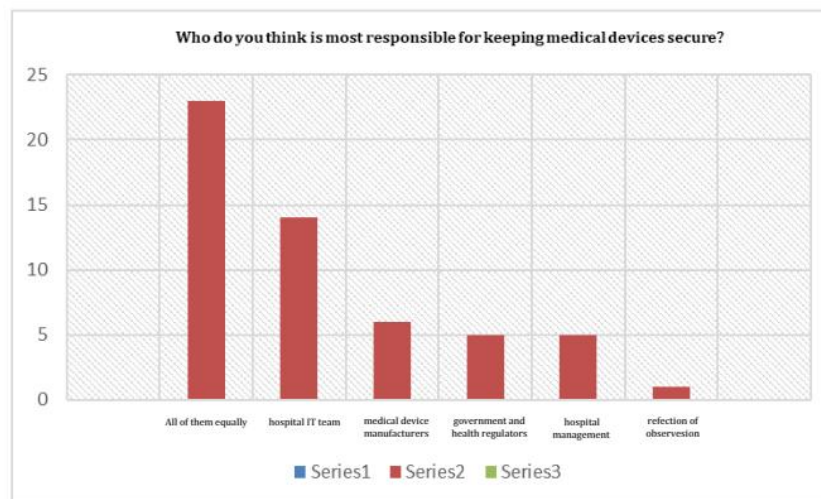
Following graph shows the bar charts of the singles most important research gap the IoMT cybersecurity field needs to address and most people answered saying real world clinical access and testing is the most important thing to address followed by human factors and other stuffs.

4.



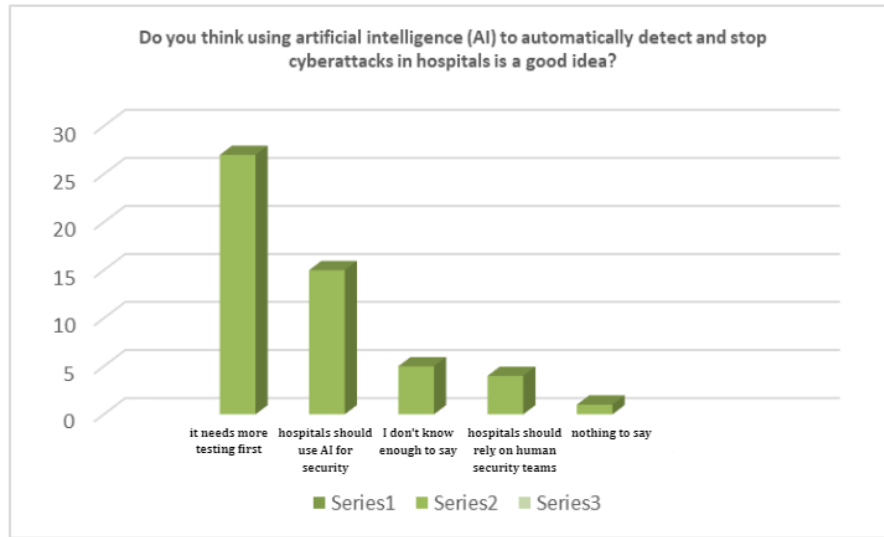
This graph represents how safe the responders think the medical devices are from the hackers well most people expressed concern and said its not very safe but some people also believed its moderately same followed by few people also thought that it's not safe enough

5.



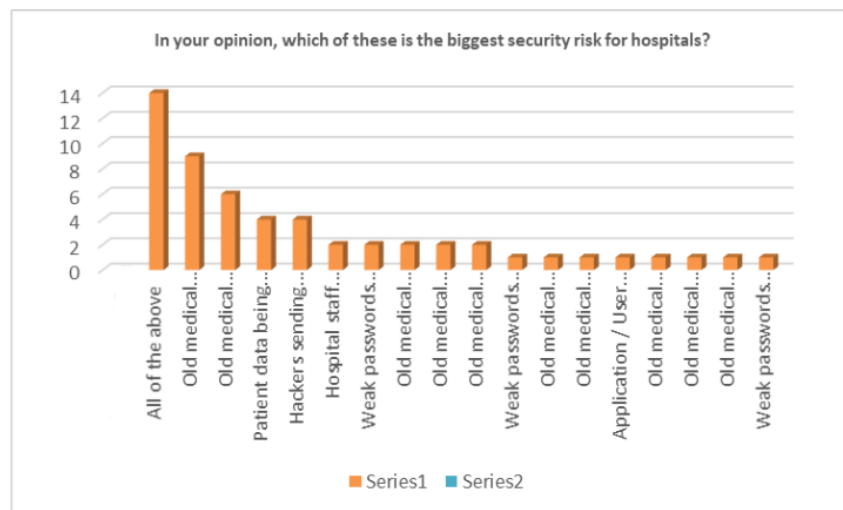
Graph that's given before shows the analysis of the most responsible entity for keeping medical devices secure. After analyzing it can be seen that most people said all of the above, all of the above includes hospital it team, medical device manufactures, government and health registers, hospital management etc.

6.



Above graph represents that what the responders of the survey thinks about that using artificial intelligence to automatically detect and stop cyberattacks in hospitals is a good idea or not and most people answered with that it needs more testing before launching it in full blown thing in hospital management.

7.



Following graph shows according to responders' opinion which of these is the biggest security risk of hospitals and most people said all of the above as in old medical supplies, patients' data being hacked, application issues etc.

The following section shows the responses of people that are found out after analyzing the survey and these opinions should be taken in concern.

5. Cybersecurity Challenges in IoMT

5.1 Device-Level Vulnerabilities

IoMT devices are structurally insecure by design. They were engineered to optimize clinical functionality, reliability, and power efficiency — not to defend against adversarial actors [1], [9]. This foundational design priority manifests in several interconnected vulnerability categories that research has consistently documented across device types and deployment contexts.

The first category is the absence of built-in security features. Many IoMT devices ship without strong authentication protocols, support for encrypted communication, or mechanisms for receiving security updates after deployment. Legacy medical devices — equipment acquired years or decades before current cybersecurity standards emerged — create significant challenges, as these devices frequently operate on outdated operating systems that no longer obtain security updates or vendor maintenance. Studies show that nearly sixty percent of medical devices in use rely on obsolete software platforms.



Fig. 6. Cybersecurity Attack Surface Map of a Hospital Environment.

The second category is authentication weakness. Studies have found that roughly twenty percent of deployed medical devices depend on default login credentials or weak password settings that offer minimal resistance to automated attack tools. Even more sophisticated authentication systems, including biometric identification, carry vulnerabilities to spoofing techniques that device-level security controls cannot independently address. Figure 6 shows from which places the attacks can occur in hospital, it is just a visual representation.

The third category is device heterogeneity. Healthcare environments contain equipment from dozens of manufacturers, each implementing distinct operating systems, communication protocols, and security architectures. This diversity creates significant complexity for hospital IT departments attempting to apply consistent security policies, and it means that a single insecure device can serve as an entry point into broader infrastructure.

Empirical risk assessment confirms the practical significance of these vulnerabilities. Analysis across five major IoMT device categories reveals that 74 percent of infusion pumps and 72 percent of imaging systems contain known cybersecurity vulnerabilities, while only 47 percent of wearable devices carry such exposures [4]. When vulnerability severity, threat probability, and operational impact are combined into composite risk scores, hospital information systems (mean score 8.1) and infusion pumps (7.8) emerge as the highest-risk device categories, with wearables at the lower end (4.6). Critically, device complexity and network integration depth — not device age or vendor origin — are the strongest predictors of elevated risk.

5.2 Data Privacy and Transmission Risks

Patient data generated by IoMT devices carries exceptional sensitivity. Medical records, medication histories, physiological measurements, and behavioral health indicators represent information whose unauthorized disclosure can cause concrete harm — financial loss through insurance fraud, reputational damage, discrimination, and direct social injury [3], [10]. This data is simultaneously highly valuable to malicious actors and, in many IoMT implementations, insufficiently protected during collection, transmission, and storage. Unencrypted data transmission represents one of the most consistently documented vulnerabilities in IoMT deployments. Sensitive patient data traversing wireless networks without adequate encryption is susceptible to interception through passive monitoring of network traffic — an attack requiring neither sophisticated tools nor physical access to hospital systems. Many healthcare organizations continue to operate legacy network infrastructure using insecure communication protocols that predate current encryption standards.

Data integrity risks compound confidentiality concerns. The accuracy of health data is not merely a privacy matter but a patient safety issue: clinical decisions depend on the precision of readings from biosensors, imaging systems, and monitoring equipment. Malicious tampering with data values can corrupt the information on which diagnostic and therapeutic decisions rest. The interconnected nature of IoMT ecosystems means that compromised data can propagate across electronic health records, clinical decision support systems, and treatment delivery devices before the corruption is detected. Figure 7 is the graphical representation of the vulnerability percentages that should be a matter of concern.

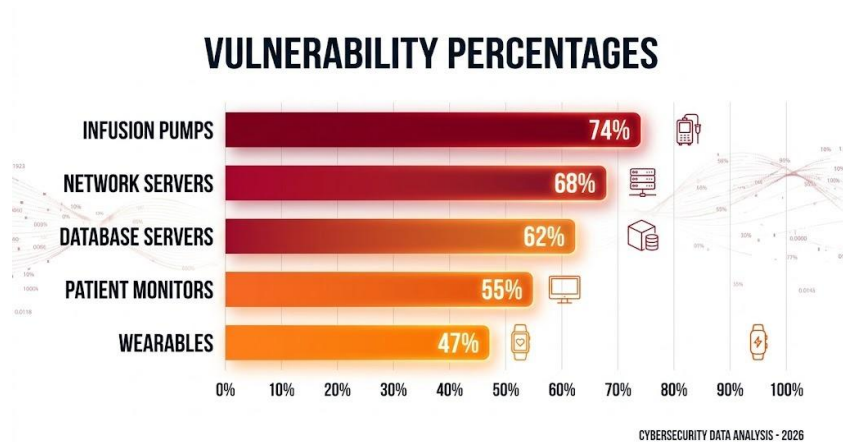


Fig. 7. Vulnerability Prevalence Percentages by IoMT Device Category.

5.3 Network-Level Threats

Beyond device and data vulnerabilities, IoMT ecosystems face network-level attack vectors that can disrupt healthcare operations independently of any individual device's security posture. Distributed Denial of Service attacks represent the most operationally significant of these threats [5], [11]. In a DDoS attack, massive amounts of harmful network traffic are sent toward hospital servers or network infrastructure, exceeding their operational capacity and making them inaccessible to authorized users. When IoMT devices become compromised and are integrated into botnets, they may contribute to attacks aimed not only at their own healthcare institution's systems but also at external networks and organizations.

The healthcare consequences of successful DDoS attacks extend beyond data loss or financial cost to direct patient care disruption. Delayed access to electronic health records during acute medical events, interrupted monitoring of critical care patients, and unavailability of telemedicine services all represent scenarios in which network-level attacks translate into clinical harm. Research identifies multiple attack variants relevant to IoMT environments, including volumetric attacks, application-layer attacks, and IoT-specific botnet attacks.



Fig. 8. Ransomware Attack Propagation Pathway in Hospital Networks.

Ransomware represents a related and increasingly prevalent threat. Cyber attackers encrypt hospital records or disrupt essential systems and then demand ransom payments to restore access. IoMT devices often function as entry points for infection, enabling ransomware to gain access to hospital networks before spreading to more critical systems. Studies estimate that nearly 89 percent of healthcare institutions use IoMT devices susceptible to ransomware attacks [\[10\]](#) — a figure that underscores both the pervasiveness of the risk and the inadequacy of current protective measures. The visual example is shown in figure 8.

5.4 Authentication and Access Control Failures

Weak authentication mechanisms constitute one of the most tractable yet persistently unresolved cybersecurity challenges in IoMT. The consequences of authentication failure are direct: unauthorized users who gain access to IoMT devices can read sensitive patient data, manipulate device settings, disable monitoring functions, or establish persistent backdoors within hospital networks. The stakes are elevated by the critical nature of the devices involved — unauthorized control of an infusion pump could alter drug dosing with lethal consequences.

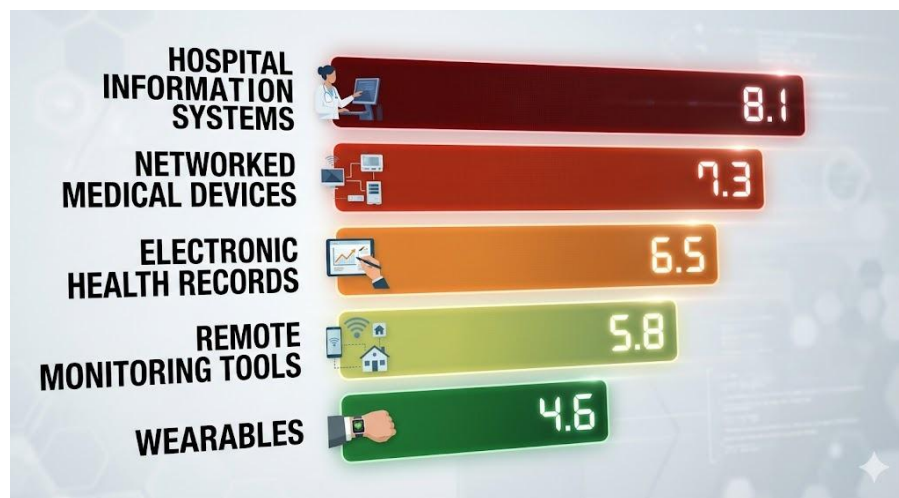


Fig. 9. Composite Cybersecurity Risk Scores by Device Category.

Access control failures compound authentication weaknesses. Many healthcare institutions integrate medical devices into hospital networks without enforcing proper network segmentation or adequate access control mechanisms. Figure 9 is the visual example of the fact of Composite Cybersecurity Risk Scores by Device Category. This absence of network segmentation means that once an attacker compromises a single device, lateral movement within the broader network becomes feasible. The integration of IoMT devices with electronic health records and administrative systems that all papers in the literature identify as a clinical benefit simultaneously makes the consequences of any single access control failure significantly more severe.

5.5 Insider Threats and Human Factors

Cybersecurity discourse in IoMT predominantly frames the threat environment in terms of external actors exploiting technical vulnerabilities. This framing, while not inaccurate, systematically underweights the role of authorized users in creating and enabling security failures [1], [3]. Healthcare personnel with legitimate access to IoMT devices and networks — clinical staff, IT administrators, third-party vendors, and maintenance contractors — represent a distinct threat category that technical perimeter-defense controls cannot adequately address.



Fig. 10. *Intentional and Accidental Insider Threat Mechanisms in IoMT.*

Insider threats operate through two distinct mechanisms. Intentional misuse involves authorized users deliberately accessing, exfiltrating, or manipulating data for personal gain or malicious purpose. The high monetary value of medical records on illicit markets creates financial incentives for this category of threat. Accidental compromise, statistically more common, involves security failures resulting from negligence, inadequate training, or the pressure to prioritize clinical efficiency over security protocol adherence. Healthcare workers operating under time pressure in clinical environments will bypass security controls when those controls impede patient care. Figure 10 is the animated visual example of the situation.

5.6 Regulatory and Standardization Gaps

The regulatory landscape governing IoMT security remains fragmented, evolving, and inconsistently enforced across jurisdictions. In the United States, HIPAA defines fundamental requirements for safeguarding electronic protected health information (ePHI) but was drafted before the current IoMT ecosystem existed and does not specify technical security standards with the precision that modern threat environments require. In the European Union, GDPR imposes more stringent data protection obligations but similarly does not prescribe specific IoMT security architectures.



Fig. 11. Distribution of Risk Levels Across 150 IoMT Devices.

In the above figure a pie chart can be seen which tells the percentages of the distribution of the risk factors or levels across 150 IoMT devices.

The absence of standardized security protocols for IoMT devices creates a landscape in which individual manufacturers implement security measures according to their own judgment, resources, and competitive incentives. This heterogeneity means that devices from different vendors may be incapable of interoperating securely. The practical consequence for healthcare organizations is an inability to implement consistent security practices across their device ecosystems, compounded by insufficient regulatory enforcement mechanisms.

Table III: IoMT Cybersecurity Threat Landscape — Summary Matrix

Threat Category	Attack Vector	Primary Impact	Highest-Risk Devices
Device Vulnerability	Unpatched firmware, default credentials	Unauthorized access, device control	Infusion pumps (74%), imaging (72%)
Data Interception	Network monitoring, MITM	Privacy breach, data manipulation	All wireless pathways
Ransomware	IoMT device as infection vector	Service disruption, extortion	Hospital info systems (8.1)

Threat Category	Attack Vector	Primary Impact	Highest-Risk Devices
DDoS Attacks	Botnet of compromised devices	Care service unavailability	Network-connected monitors
Insider Threat	Credential misuse, negligence	Data exfiltration, modification	EHR-integrated devices
Authentication. Failure	Brute force, credential stuffing	Network infiltration	Devices with weak credentials (20%)

6. Mitigation Strategies and Security Frameworks

6.1 Multi-Layered Security Approaches

The dominant paradigm in IoMT cybersecurity practice and prescriptive research recommends the concurrent deployment of multiple complementary security controls spanning technical, procedural, and organizational domains [1], [2]. This multi-layered or defense-in-depth approach rests on the premise that no single control is sufficient, and that the failure of any one layer should be contained by others operating in parallel. At the technical core of this paradigm sit encryption and authentication. Encryption of data at rest using AES-256 and of data in transit using TLS protects against interception and unauthorized access. Multi-factor authentication — combining password credentials with biometric verification, hardware tokens, or time-based one-time passwords — reduces the risk posed by compromised credentials. Role-Based Access Control limits each user's access to the data and functions required for their specific clinical or administrative role, applying the principle of least privilege.



Fig. 13. Defense-in-Depth Concentric Security Framework for IoMT.

Whereas figure 12 shows the very depth of defense in Concentric Security Framework for IoMT. Network segmentation represents a structural complement to device-level and credential-level controls. By creating dedicated network zones for IoMT devices — separated from clinical workstations, administrative systems, and internet-facing services — organizations can limit the lateral movement available to an attacker who has compromised a single device. Micro-segmentation provides finer-grained control. Procedural controls — regular software and firmware updates, vulnerability assessment programs, penetration testing, and incident response planning — address the temporal dimension of security that technical controls alone cannot manage. Devices that are secure at deployment become vulnerable as new attack techniques emerge; consistent patching and testing regimes are necessary to maintain security posture over time. Staff training and security awareness programs address the human factors dimension.

6.2 Deep Reinforcement Learning

A growing body of research argues that conventional multi-layered controls are structurally insufficient for the dynamic, evolving threat environment that IoMT systems face [5], [11]. This position motivates the development of adaptive security frameworks capable of learning from observed attack patterns and adjusting their defensive responses in real time.

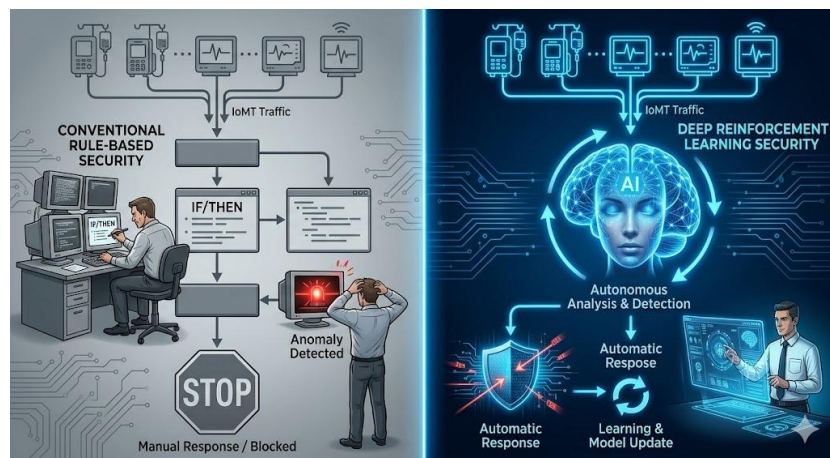


Fig. 13. Comparison of DRL-Based and Conventional Intrusion Detection.

Deep Reinforcement Learning represents the most prominent technical approach in this category. DRL combines deep learning's capacity to extract complex patterns from large, high-dimensional datasets with reinforcement learning's ability to formulate optimal decision-making approaches through repeated interaction with a given environment[figure-13]. Applied to IoMT network security, DRL-based systems can function as intelligent intrusion detection mechanisms that not only identify known attack signatures but generalize to novel variants by recognizing anomalous patterns in network traffic, device behavior, and data flows.

Experimental evaluations of DRL-based approaches demonstrate substantial performance advantages over conventional rule-based intrusion detection systems in controlled settings [5].

Ensemble learning frameworks combining multiple classification algorithms have achieved detection accuracy rates approaching 99 percent on benchmark IoMT security datasets. Deep learning models applied to network traffic analysis have shown particular effectiveness against multi-vector botnet attacks.

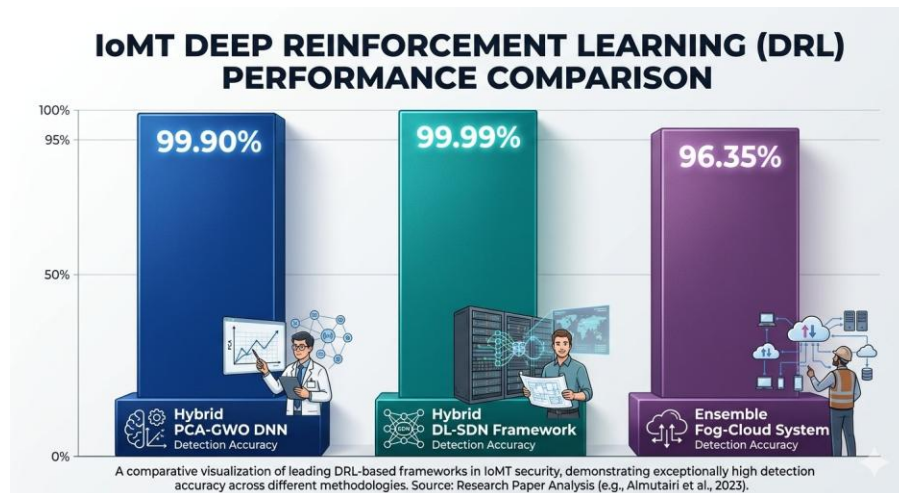


Fig. 14. Detection Accuracy of Three DRL-Based Security Frameworks

Critical limitations constrain the current state of DRL-based security research. All evaluated frameworks have been tested on benchmark datasets or simulated environments rather than live clinical deployments. The computational requirements of DRL systems may exceed the processing capacity available in resource-constrained IoMT devices. Adversarial attacks — where malicious actors deliberately manipulate network behavior to confuse learning algorithms — represent an emerging vulnerability specific to AI-driven security systems.

6.3 Blockchain Technology for Data Integrity and Trust

Blockchain technology offers a distinctive approach to IoMT security grounded not in threat detection but in data integrity assurance [14]. A blockchain is a distributed ledger in which records are stored in cryptographically linked blocks across multiple nodes — a structure that makes unauthorized modification of any stored record computationally infeasible without consensus from a majority of the network.

Proposed applications of blockchain in IoMT security span several use cases. Decentralized authentication systems use blockchain to manage device identity and access credentials without a single central authority. Immutable audit logs record all data access and modification events in a form that cannot be altered after the fact. Smart contracts automate and enforce data sharing policies, ensuring that patient data is shared only under conditions that satisfy predefined privacy and consent requirements.



Fig. 15. Blockchain Technology Applications in IoMT Security Architecture.

Practical limitations constrain blockchain's applicability in IoMT contexts. Transaction processing overhead introduces latency that may be incompatible with real-time clinical applications. Scalability challenges emerge as the number of participating devices and transactions grows. Private blockchain implementations address some scalability concerns by restricting participation to authorized nodes, but at the cost of the decentralization properties that provide blockchain's security guarantees. Figure 15 shows the blockchain technology applications in IoMT security architecture, it is visually described the figure above.

6.4 Network Security Techniques

Research on IoMT network security has produced a taxonomy of defensive mechanisms addressing the DDoS and botnet threats that represent the most operationally disruptive attack categories [5]. These mechanisms operate at different points in the attack lifecycle and carry distinct performance profiles with respect to detection accuracy, response latency, scalability, and false positive rates.

Intrusion Detection and Prevention Systems monitor network traffic continuously, applying rule-based or machine learning-based analysis to identify and block malicious traffic. IDS solutions perform well against known attack signatures but struggle with novel variants; IPS solutions add active blocking capabilities but require careful tuning to avoid disrupting legitimate clinical traffic. Anomaly detection systems complement signature-based approaches by identifying deviations from established baseline behavior.

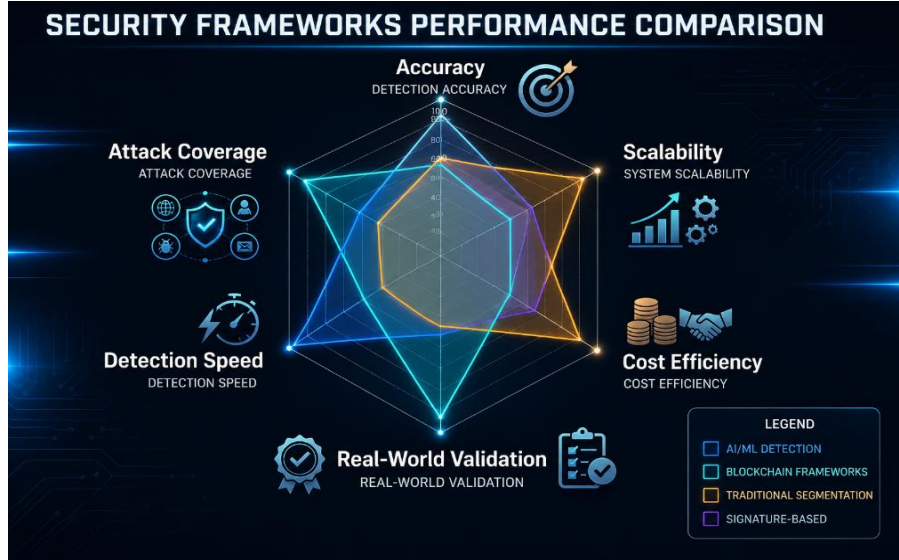


Fig. 16. Comparative Assessment of Six IoMT Security Frameworks.

Traffic filtering, rate limiting, and network access control lists provide coarser-grained but computationally lightweight defensive layers. Software-Defined Networking enables centralized traffic management and dynamic rerouting. Cloud-based DDoS mitigation services leverage distributed infrastructure to absorb attack traffic at a scale beyond what individual hospital networks can manage internally. Collaborative defense frameworks pool threat intelligence across multiple healthcare institutions.

Table IV: Comparative Analysis of IoMT Security Frameworks

Framework	Threat Type	Validation	Strengths	Limits
Multi-Layer Controls	Broad spectrum	Literature synth.	Comprehensive coverage	No real-world test
DRL-Based Detection	DDoS, botnets, anomalies	Benchmark data	Adaptive, ~99% accuracy	Sim-only
Blockchain Integrity	Data tampering, audit	Prototype	Tamper-proof, decentralized	Latency
Network Segmentation	Lateral movement	Architecture	Limits breach spread	Interop conflict
Risk Assessment	Device vulnerability	Simulated	Quantified priority	150-device sim
Collaborative Defense	Coordinated attacks	Theoretical	Cross-institution intel	Culture barriers

7. Critical Analysis of the Research Landscape

7.1 Evidentiary Quality and Methodological Limitations

A frank assessment of the IoMT cybersecurity literature reveals a field whose prescriptive confidence substantially exceeds its empirical foundation. The majority of published work consists of literature reviews and descriptive syntheses that aggregate existing knowledge without generating new primary data. Where empirical work does exist, it relies predominantly on simulated environments, publicly available vulnerability databases, and benchmark datasets rather than measurements taken in operational clinical settings.

This methodological pattern has direct consequences for the reliability of published findings. Vulnerability prevalence estimates, risk scores, and framework performance metrics generated in simulated environments may not accurately reflect conditions in real hospital networks. The finding that 37 percent of deployed IoMT devices fall into the high-risk category and that hospital information systems carry the highest average risk scores [4] — while methodologically the strongest quantitative finding in the current literature — was generated from a 150-device simulated dataset. Its external validity to the diverse, globally distributed population of actual hospital deployments remains empirically unestablished.

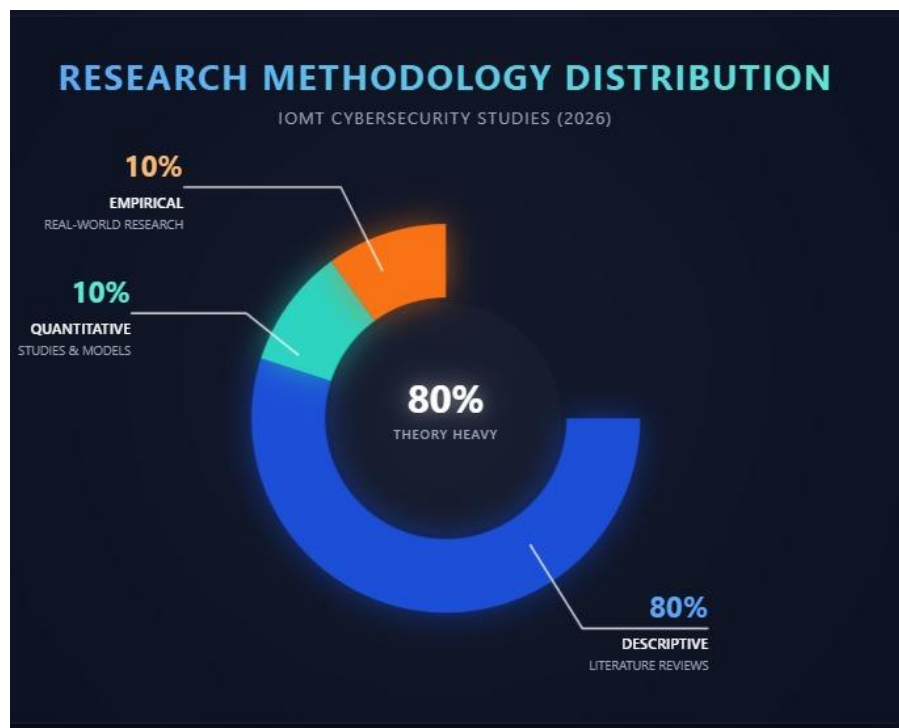


Fig. 17. Distribution of Research Methodologies in IoMT Literature.

Figure 17 is a pie chart as well to represent graphically the distribution of research methodologies in IoMT literature sectors. A further evidentiary concern is the absence of longitudinal data. All published work captures vulnerability and risk at a single point in time. Whether IoMT security is improving or deteriorating as the ecosystem scales, as new device categories are introduced, and as both defensive capabilities and attack techniques evolve — this trajectory question is currently unanswerable from available evidence.

7.2 Foundational Assumptions and Their Risks

Beyond methodological limitations, the IoMT cybersecurity literature rests on several foundational assumptions that are neither explicitly acknowledged nor empirically tested. The most consequential assumption is that technical security controls, if correctly specified, will be consistently implemented and used as intended by clinical staff. Every mitigation recommendation in the literature presupposes implementation fidelity. Evidence from healthcare quality improvement research demonstrates that clinical staff routinely bypass security controls perceived as impeding patient care, particularly under time pressure.

A second consequential assumption is that more security technology, layered additively, produces proportionally more security. The literature consistently recommends adding successive security mechanisms without addressing the possibility that complexity itself generates vulnerability. Each additional layer creates integration points that may carry their own exploitable weaknesses, increases the cognitive and operational burden on security administrators, and raises the probability of misconfiguration. A third assumption concerns regulatory compliance as a proxy for security effectiveness. Multiple papers treat HIPAA and GDPR compliance as meaningful indicators of security adequacy. If compliance primarily functions as a documentation and audit exercise rather than an operational security outcome, then regulatory compliance recommendations would misdirect institutional resources away from effective controls toward bureaucratic adherence.

7.3 The Contested Landscape: Active Debates

Several substantive disagreements continue to divide the IoMT cybersecurity research community, reflecting mutually exclusive interpretations of empirically contested issues. The first major debate concerns the relative primacy of device-level versus network-level threats. One line of research emphasizes structural vulnerabilities at the device level as the fundamental sources of security failure. In contrast, an opposing viewpoint prioritizes network-level threats, including DDoS attacks, botnet activity, and traffic-layer manipulation, as the dominant operational risks.



Fig. 18. Three Unresolved Debates in IoMT Cybersecurity Research.

The second debate centers on the adequacy of conventional security frameworks. One perspective maintains that established multi-layered security controls, when correctly implemented, are sufficient to mitigate IoMT risks. Conversely, another viewpoint argues that the rapidly evolving and dynamic nature of IoMT threat environments renders static, layered defenses inadequate. Proponents of this view advocate for adaptive, AI-driven security architectures capable of responding to emerging threats in real time.

The third debate involves blockchain's architectural status. Some researchers treat blockchain as one enabling technology among several equals, valuable in specific contexts but not fundamentally different from other security tools. Others argue that blockchain's decentralized immutability makes it architecturally essential — the only basis for trustworthy data integrity in an environment where no single institutional authority can be fully trusted.

8. Research Gaps and Future Directions

8.1 Real-World Clinical Validation

The most significant gap in IoMT cybersecurity research is the complete absence of security framework testing in operational clinical environments. Every framework, model, and recommendation in the current literature has been developed and evaluated in simulation or through analysis of existing literature. The specific conditions of real hospital deployments — strict uptime requirements that prevent security updates from being applied during device operation, legacy device integration that constrains architectural choices, variable staff behavior under clinical pressure, and the complex interplay between security requirements and patient care imperatives — have not been studied empirically. Closing this gap requires institutional partnership arrangements allowing security researchers to work within operational hospital environments under IRB oversight, combined with digital twin infrastructure that can mirror live hospital network conditions for experimental testing without exposing patient systems to risk.

8.2 Human Factors and Behavioral Security Research

The role of human behavior in IoMT security failures is widely acknowledged in the literature, yet remains insufficiently investigated. Although insider threats and human error are frequently identified as critical risk factors, there is a notable absence of empirical studies that quantify their contribution to security incidents relative to technical vulnerabilities. Furthermore, existing research does not adequately examine the conditions under which clinical staff fail to comply with established security protocols. Addressing this gap necessitates the integration of interdisciplinary methodologies, particularly from fields such as organizational behavior, human–computer interaction, and qualitative research. However, these perspectives are largely underrepresented in the predominantly technical IoMT cybersecurity literature, thereby limiting a comprehensive understanding of the human factors that influence system security. In figure 19 the research gaps are shown visually, clearly and beautifully.



Fig. 19. Key Research Gaps in IoMT Cybersecurity.

8.3 Standardized Risk Assessment Methodology

No validated, standardized methodology for assessing cybersecurity risk across IoMT device ecosystems currently exists. Individual researchers have proposed assessment frameworks with varying parameters, scoring approaches, and device taxonomies — but no cross-institutional validation has established which approach most accurately predicts real-world security failures. A consensual, validated risk assessment standard would enable meaningful comparison of security postures across institutions, inform procurement decisions, and provide a baseline for measuring security improvement over time.

8.4 Longitudinal Security Trajectory Research

Whether IoMT security is improving or deteriorating over time — and at what rate — is an empirically unanswered question. As device ecosystems scale, as legacy equipment accumulates, as attack techniques evolve, and as defensive capabilities develop, the net security trajectory of the global IoMT ecosystem is unknown. Multi-institution longitudinal studies tracking vulnerability prevalence, incident frequency, and mitigation effectiveness across time would provide the evidence base needed to evaluate whether current research and practice are producing meaningful security improvements.

8.5 Security for Emerging Device Categories

The security implications of the most resource-constrained emerging IoMT device categories — ingestible sensors, Bio-Nano Things, and implantable molecular-level devices — have received almost no research attention. These devices operate under computational, power, and size constraints that make conventional cryptographic and authentication approaches infeasible. Novel lightweight security primitives designed specifically for sub-milliwatt power budgets and minimal processing capacity are needed, requiring cross-disciplinary collaboration between biomedical engineers and security researchers.

9. Conclusion

The IoMT occupies an increasingly central position in modern healthcare delivery, and its cybersecurity challenges are correspondingly consequential. This survey has mapped the current state of knowledge across five analytical dimensions: the ecosystem's layered architecture, the principal threat categories targeting each layer, the mitigation frameworks the research community has proposed, the critical analysis that those frameworks require, and the research gaps that constrain progress. Several findings stand with reasonable confidence. The majority of deployed IoMT devices carry documented cybersecurity vulnerabilities, and device complexity combined with network integration depth predicts risk level more reliably than device age or vendor origin [\[4\]](#). Among the empirically analyzed samples, infusion pumps and hospital information systems were identified as the device categories with the greatest level of risk. No single security control is adequate; effective protection requires multiple complementary mechanisms operating across technical, procedural, and organizational domains. Regulatory compliance frameworks are necessary but insufficient technical security tools.

The most important finding, however, is not a positive result but an absence. No security framework proposed in this literature has been tested in an operational clinical environment. Every quantitative risk score, every performance metric, every architectural recommendation rest on simulation, synthesis, or benchmark evaluation. The gap between the technical sophistication of proposed solutions and the evidential basis for confidence in those solutions is the defining characteristic of the current research landscape — and its closure is the field's most pressing priority. The single open question whose resolution would most reshape both research priorities and institutional investment is direct: do adaptive AI-driven security frameworks, specifically combinations of deep reinforcement learning and blockchain technology, actually outperform conventional multi-layered controls when deployed in operational hospital environments under real clinical constraints? Until that question is answered with empirical evidence from live deployments, the field's recommendations — however technically rigorous in conception — remain proposals rather than proofs. The patients whose safety depends on IoMT security deserve the difference.

ACKNOWLEDGMENT

The authors would like to express their gratitude to faculty member **Dr. Subhra Prosun Paul** from the Department of Computer Science and Engineering at University of Asia Pacific for his valuable guidance and constructive feedback throughout this survey.

REFERENCES

- [1] S. Bayyapu, "Impact of the Internet of Medical Things (IoMT) on healthcare cybersecurity," *Int. J. Innov. Eng. Manag. Res.*, vol. 12, no. 12, pp. 146–153, 2023.
- [2] J. M. Mutua and H. J. Bitok, "The Internet of Medical Things (IoMT): A comprehensive review of architecture, enabling technologies, security challenges, and future perspectives," *Eng. Technol. J.*, vol. 10, no. 8, pp. 6321–6334, 2025.
- [3] A. Yazid, "Cybersecurity and privacy issues in the Internet of Medical Things (IoMT)," *Eigenpub Rev. Sci. Technol.*, vol. 7, no. 1, 2023.
- [4] M. Akram, W. Khan, M. D. Rasheed, M. Imran, M. W. Iqbal, A. Delshadi, and M. Sultana, "Cybersecurity risk assessment model for Internet of Medical Things (IoMT) devices in healthcare systems," *Spectrum Eng. Sci.*, vol. 4, no. 3, pp. 312–326, 2026.
- [5] H. A. Tarish, R. Hassan, K. A. Z. Ariffin, and M. M. Jaber, "Network security framework for Internet of Medical Things applications: A survey," *J. Intell. Syst.*, vol. 33, art. 20230220, 2024.
- [6] S. Razdan and S. Sharma, "Internet of Medical Things (IoMT): Overview, emerging technologies, and case studies," *IETE Tech. Rev.*, vol. 39, no. 4, pp. 775–788, 2022.
- [7] M. Papaioannou et al., "A survey on security threats and countermeasures in Internet of Medical Things (IoMT)," *Trans. Emerg. Telecommun. Technol.*, vol. 33, no. 6, e4049, 2022.
- [8] A. A. El-Saleh et al., "The Internet of Medical Things (IoMT): Opportunities and challenges," *Wireless Netw.*, vol. 31, no. 1, pp. 327–344, 2025.
- [9] J. P. A. Yaacoub et al., "Securing internet of medical things systems: Limitations, issues and recommendations," *Future Gener. Comput. Syst.*, vol. 105, pp. 581–606, 2020.
- [10] N. M. Thomasian and E. Y. Adashi, "Cybersecurity in the Internet of Medical Things," *Health Policy Technol.*, vol. 10, no. 3, art. 100549, 2021.
- [11] R. U. Rasool et al., "Security and privacy of Internet of Medical Things: A contemporary review in the age of surveillance, botnets, and adversarial ML," *J. Netw. Comput. Appl.*, 2022.
- [12] B. Shanmugam and S. Azam, "Risk assessment of heterogeneous IoMT devices: A review," *Technologies*, vol. 11, no. 1, art. 31, 2023.
- [13] B. Bhushan et al., "Towards a secure and sustainable Internet of Medical Things (IoMT): Requirements, design challenges, security techniques, and future trends," *Sustainability*, vol. 15, no. 7, art. 6177, 2023.
- [14] R. Kumar and R. Tripathi, "Towards design and implementation of security and privacy framework for Internet of Medical Things (IoMT) by leveraging blockchain and IPFS technology," *J. Supercomput.*, vol. 77, pp. 7916–7955, 2021.
- [15] A. Ghubaish et al., "Recent advances in the Internet-of-Medical-Things (IoMT) systems security," *IEEE Internet Things J.*, vol. 8, no. 11, pp. 8707–8718, 2021.